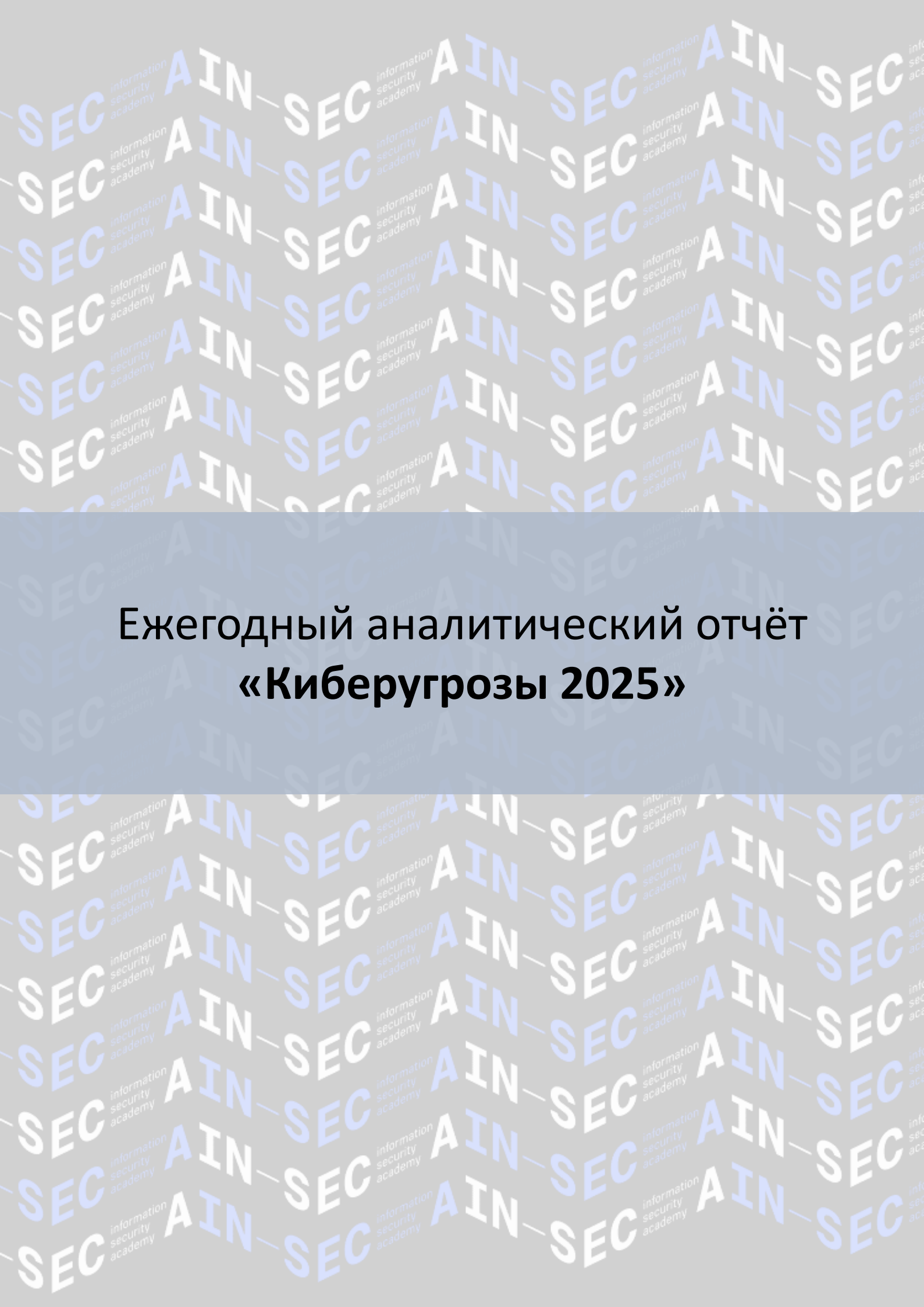


The background of the entire page is a repeating pattern of the words 'SEC' and 'AIN' in a light blue color, separated by a horizontal line. Below this line, the words 'information security academy' are written in a smaller, lighter blue font. The pattern is tilted at an angle, creating a sense of depth and movement.

Ежегодный аналитический отчёт «Киберугрозы 2025»

СОДЕРЖАНИЕ

Введение

Основные результаты

Покрытие ландшафта угроз

Ландшафт угроз ИБ 2025

Атаки на образовательную сферу

Активные АРТ-группировки

Вредоносное ПО

Уязвимости

Утечки

Supply chain

DDoS-атаки

Прогноз 2026

ОСНОВНЫЕ РЕЗУЛЬТАТЫ

Заведено инцидентов на основании IOC's



Отправлено IOC's на блокировку СЗИ



400

Разработано продуктов
аналитики

500

Создано корреляционных
правил на основании продуктов
аналитики

ОСНОВНЫЕ РЕЗУЛЬТАТЫ



Релевантные: 200



Применимы: 111

Наиболее резонансные уязвимости:

- CVE-2023-32434, CVE-2023-32439 – уязвимости, использовавшиеся в целевой атаке на пользователей устройств **Apple**.
- CVE-2023-28252 – уязвимость, связанная с повышением привилегий до уровня SYSTEM в драйвере **Windows Common Log File System (CLFS)**.
- CVE-2023-3029 – 0-day уязвимость в **Google Chrome**, которая позволяет удаленному злоумышленнику потенциально использовать повреждение кучи через созданную HTML-страницу.



Выявлено утечек данных
ООО «Инсека»: 0

ПОКРЫТИЕ ЛАНДШАФТА УГРОЗ

10 наиболее встречающихся техник MITRE ATT&CK
в подготовленных отчётах

Техника	Название техники	Кол-во
T1059	Использование интерпретаторов командной строки и сценариев	100
T1566	Фишинг	90
T1221	Внедрение в шаблоны	80
T1538	Кража сессионных куки	70
T1557	Человек посередине	60
T1036	Маскировка под легального пользователя или инструмент	50
T1053	Запланированная задача (задание)	40
T1534	Внутренний целевой фишинг	30
T1580	Исследование облачной инфраструктуры	20
T1210	Эксплуатация удаленных служб	10

ПОКРЫТИЕ ЛАНДШАФТА УГРОЗ

Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access
Drive-by Compromise	Command and Scripting Interpreter	Account Manipulation	Abuse Elevation Control Mechanism	Abuse Elevation Control Mechanism	Brute Force
Supply Chain Compromise	Exploitation for Client Execution	Boot or Logon Autostart Execution	Access Token Manipulation	Access Token Manipulation	Credentials from Password Stores
Valid Accounts	Inter-Process Communication	Boot or Logon Initialization Scripts	Boot or Logon Autostart Execution	Trusted Developer Utilities Proxy Execution	Input Capture
External Remote Services	User Execution	Create Account	Boot or Logon Initialization Scripts	Debugger Evasion	Adversary-in-the-Middle
	Windows Management Instrumentation	Create or Modify System Process	Create or Modify System Process	Deploy Container	Modify Authentication Process
	Deploy Container	Event Triggered Execution	Exploitation for Privilege Escalation	Build Image on Host	Steal Web Session Cookie
		Hijack Execution Flow	Hijack Execution Flow	Domain Policy Modification	Exploitation for Credential Access

Discovery	Lateral Movement	Collection	Command And Control	Exfiltration	Impact
Account Discovery	Lateral Tool Transfer	Archive Collected Data	Application Layer Protocol	Automated Exfiltration	Data Destruction
Application Window Discovery	Remote Services	Data from Local System	Data Encoding	Exfiltration Over Alternative Protocol	Data Encrypted for Impact
File and Directory Discovery	Software Deployment Tools	Data Staged	Data Obfuscation	Exfiltration Over C2 Channel	Data Manipulation
Network Service Scanning	Use Alternate Authentication Material	Email Collection	Dynamic Resolution	Exfiltration Over Web Service	Defacement
Network Share Discovery	Exploitation of Remote Services	Input Capture	Encrypted Channel	Scheduled Transfer	Disk Wipe
Network Sniffing	Internal Spearphishing	Data from Removable Media	Fallback Channels		Resource Hijacking
		Browser Session Hijacking	Ingress Tool Transfer		Service Stop
			Multi-Stage Channels		Account Access Removal

- ☐ Не защищены
- ☒ Защищены
- ТОП в продуктах аналитики

ЛАНДШАФТ УГРОЗ ИБ 2025

Уровень угрозы: **Max**  **Min**

Утечки

Количество утечек во втором квартале осталось на **прежнем высоком уровне**. Практически ни одна утечка не происходит без упоминания в качестве авторов украинских киберпреступных группировок.

Supply chain

Данный тип атак с каждым годом становится популярнее. Во втором квартале мы наблюдали атаки на пользователей ПО для передачи файлов **MOVEit Transfer** (около 1700 компаний пользователей по всему миру). Большое количество используемых сторонних программных решений, а также собственная разработка, значительно повышают актуальность данного вектора атаки.

Фишинг

Фишинг продолжает быть одним из **основных методов** доставки ВПО в инфраструктуру организаций и используется широким кругом атакующих (в том числе АРТ), что делает защиту от него одним из главных приоритетов. В текущем квартале зафиксировано несколько целевых фишинговых атак, направленных на российские компании.

DDoS-атаки

Не снижается количество и объёмы DDoS-атак на российские компании. В текущем квартале злоумышленники переключились на российских страховщиков. В качестве жертв чаще всего выбирают компании, проводящие активную деятельность в медиаполе. Поэтому вероятность подобной атаки на ресурсы ООО «Инсека» увеличивается.

Уязвимости

Использование уязвимостей **продолжает оставаться** одним из основных векторов атак. Как показал текущий квартал, эксплуатация некоторых уникальных уязвимостей может приводить к серьёзным последствиям, таким как взлом мобильных устройств под управлением Apple, которое произошло в текущем квартале в рамках кампании «Триангуляция».

АРТ-группировки

Вновь напомнили о себе западные АРТ, обнаруженные специалистами Лаборатории Касперского в рамках целевой атаки «Триангуляция». Также активны китайские группировки, в частности Tonto Team и Mustang Panda. Целевых вредоносных кампаний в отношении ООО «Инсека» **не выявлено**.

АТАКИ НА ОБРАЗОВАТЕЛЬНУЮ СФЕРУ

В 2025 году фиксировалась киберпреступная активность, нацеленная на образовательную сферу ряда стран. Большая часть направлена на клиентов компаний.

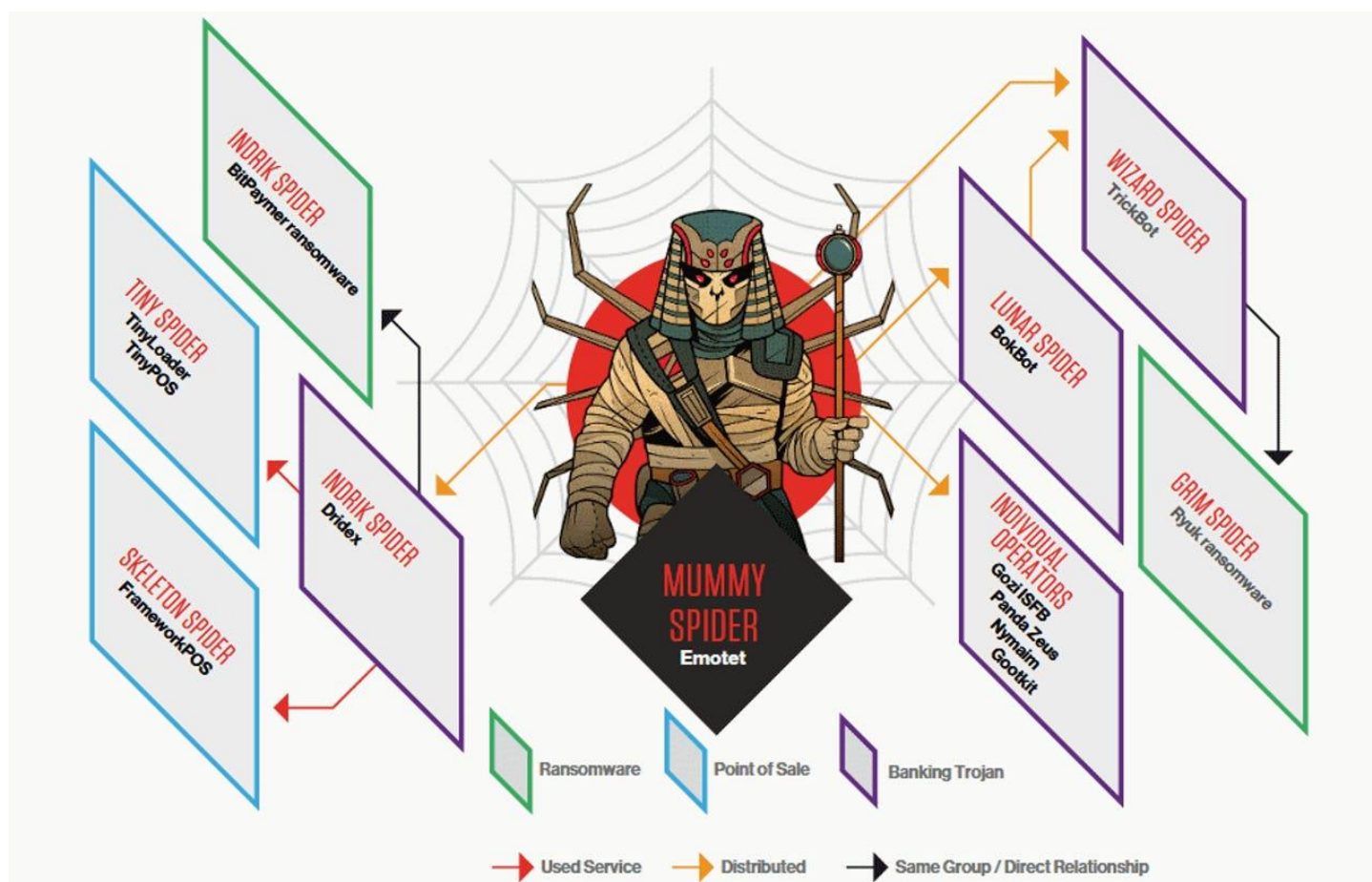
В атаках использовалось уже известное ранее ВПО.

- Троян **FakeCalls**, известный своими атаками на пользователей Android в Южной Корее, обновил тактику обхода средств безопасности. Кампания FakeCalls использует ключи подписи, украденные из законного приложения, популярного в **Южной Корее**. Поддельные приложения, использующие этот ключ, маскируются под настоящие приложения и даже используют их значки.
- В начале апреля была зафиксирована новая волна массовых рассылок трояна **QBot**. ВПО распространялось через электронные письма, написанные на разных языках (английском, немецком, итальянском и французском). За основу таких сообщений были взяты реальные деловые письма, к которым злоумышленники получили доступ, а вместе с ним и возможность отправлять участникам переписки свои сообщения.
- В апреле вирусные аналитики компании «Доктор Веб» обнаружили в каталоге Google Play вредоносные программы, распространявшиеся под видом **приложений финансовой тематики**. Например, различных пособий по инвестированию, инструментов для торговли, программ для участия в опросах и обучения. Однако их настоящей функцией была загрузка мошеннических сайтов, через которые злоумышленники пытались получить от потенциальных жертв персональные данные и похитить их деньги.

АКТИВНЫЕ АРТ-ГРУППИРОВКИ

Основные тренды

- Обнаружение атак со стороны **прозападных АРТ** с использованием 0-day уязвимостей.
- Мотивом АРТ-группировок, атакующих российские организации, является **шпионаж**.
- Основные цели – **государственные учреждения, IT-компании** и **обычные пользователи**.
- АРТ-группировками по-прежнему используется **тематика конфликта России и Украины** при распространении фишинговых писем.
- **Увеличение количества АРТ-угроз**, направленных на Россию.
- Появление **новых угроз со стороны неатрибутированных АРТ-групп**.



АКТИВНЫЕ АРТ-ГРУППИРОВКИ, АТАКУЮЩИЕ РФ

Equation (США)

1 июня на сайте ФСБ появилось сообщение о выявлении атаки **американских спецслужб**, проведенной с использованием **мобильных устройств Apple** и имеющих в них **уязвимостей**.

Заражено несколько тысяч устройств, в которых используются не только **российские sim-карты**, но и зарегистрированные на диппредставительства и посольства в России, включая страны блока НАТО и постсоветского пространства, а также Израиль, САР и КНР.

В этот же день Лаборатория Касперского сообщила о целевой атаке на **iOS-устройства**, выявленной в процессе мониторинга **собственной корпоративной Wi-Fi** сети и получившей название **Операция Триангуляция**.

Используя уязвимости в операционной системе iOS, в ходе атаки пользователю направляется невидимое iMessage-сообщение с вредоносным вложением. Внедрение происходит абсолютно скрытно и **без** какого-либо взаимодействия с пользователем.

ВПО работает исключительно в оперативной памяти и не устанавливается в системе из-за ее ограничений. Однако после перезагрузки устройства могут быть заражены снова.

Наиболее старые временные метки заражений указывают на **2019** год. На момент июня 2023 атака продолжается.

9 июня Antiy (китайская ИБ-компания) сообщила, что образцы, которые они проанализировали, и атаки, выявленные Лабораторией Касперского, исходят от **Equation**.

Образцы используют **Quantum** – систему Equation, основанную на сетевой стороне для таргетинга на уязвимости браузера и впервые раскрытую Сноуденом в **2013** году.

Watch Wolf (неизвестно)

Была зафиксирована кампания, нацеленная на компрометацию рабочих станций **бухгалтеров** российских компаний с целью последующего вывода денежных средств через онлайн - банкинг.

Группа активна с ноября 2021 года, в рамках прошлых кампаний распространение ВПО осуществлялось через фишинговые рассылки. В рамках новой кампании, которая началась не ранее ноября 2022 года, злоумышленники изменили метод распространения.

Атакующие создали сайты, имитирующие ресурсы для бухгалтеров, с которых можно загрузить различные документы, после чего с помощью SEO poisoning и покупки рекламы вывели сайты на первую страницу поисковой выдачи.

После перехода на сайт жертве предлагается загрузить искомый документ в одном из популярных форматов, например Microsoft Excel. После перехода по ссылке жертва загружает файл, но не тот, что указан в описании, а SFX - архив, содержащий ВПО. При этом файл размещен не на самом сайте: вместо этого используется система размещения контента мессенджера Discord.

Запуск загруженного файла приводит к установке бэкдора **DarkWatchman**.

ВРЕДОНОСНОЕ ПО

BabLock

Было обнаружено новое семейство вымогателей, получившее название BabLock (также отслеживаемое под именем Rorschach). Версии данного ВПО для Linux и ESXi имеют пересечения с утекшим исходным кодом шифровальщика Babuk, модуль для Windows, в свою очередь, является кастомным.

Cylance

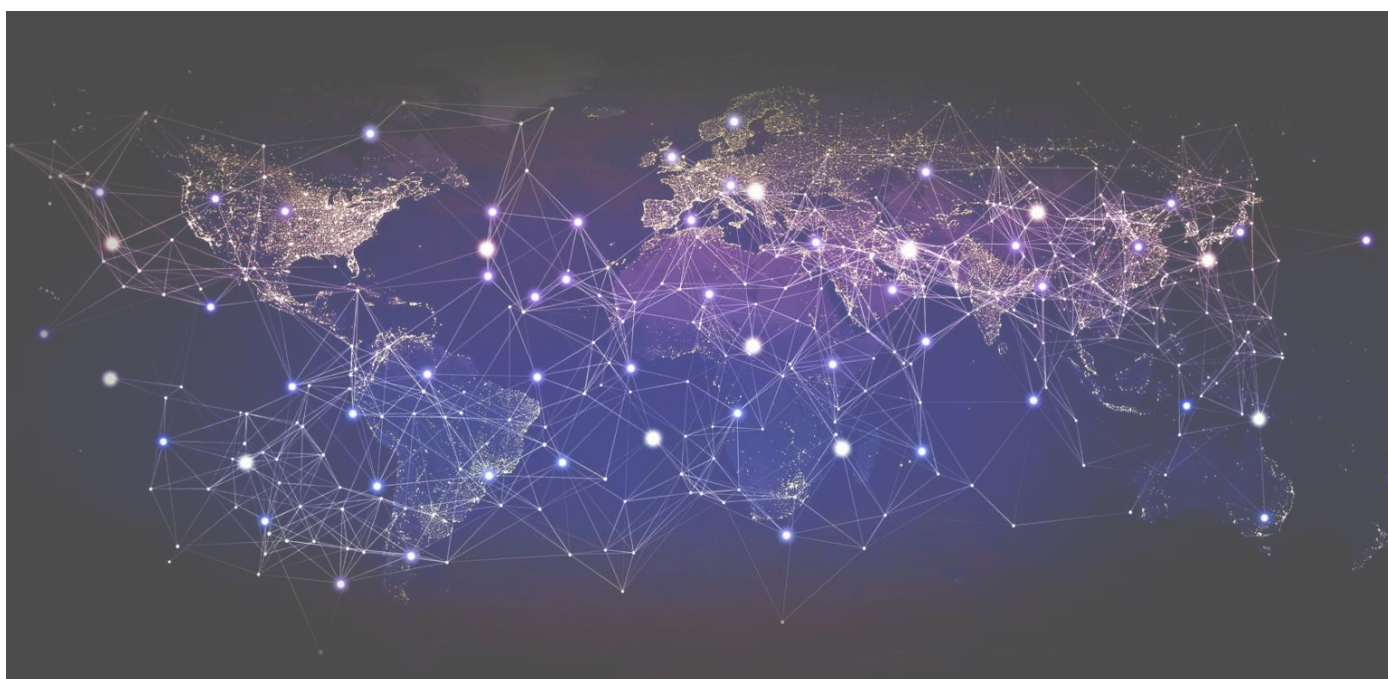
Был обнаружен и исследован экземпляр нового семейства вымогателей Cylance. ВПО нацелено на системы под управлением ОС Windows и Linux.

Предположительно, шифровальщик все еще находится в стадии разработки. Операторы не разворачивали Data Leak Site для публикации данных о жертвах, поэтому в настоящий момент доступно мало информации о них.

NoEscape

В мае 2023-го года в объявлениях на теневых форумах был замечен шифровальщик NoEscape. Он распространяется по модели Ransomware-as-a-Service (Raas).

Билдер ВПО позволяет кастомизировать исполняемый файл. В частности, с его помощью можно создавать exe и dll файлы для систем Windows, elf для Linux/ESXi, настраивать имя вымогателя и ключа шифрования, сумму выкупа и тип таймера до публикации данных.



УЯЗВИМОСТИ

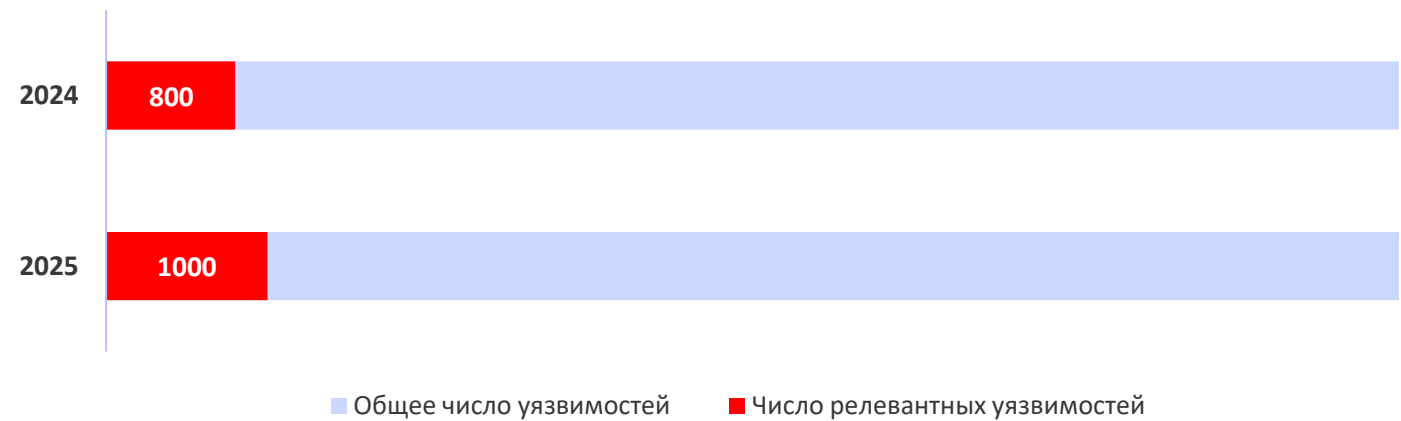


1000

Применимы на инфраструктуру ООО «Инсека»

По сравнению с 2024 годом количество зарегистрированных уязвимостей снизилось примерно на 5%.

С увеличением числа новых программных продуктов увеличивается и общее число уязвимостей. Большое число релевантных для инфраструктуры ООО «Инсека» уязвимостей напрямую связано с широким спектром программных решений, используемых в компании. Наибольший интерес представляют 0-day уязвимости, опубликованные в открытом доступе, так как по статистике, передовым АРТ-группировкам требуется **менее суток** для написания эксплойта.



ТОП УЯЗВИМОСТЕЙ

01 CVE-2023-32434, CVE-2023-32439



Apple

Уязвимости представляют угрозу для всех версий iOS, выпущенных до iOS 15.7. Они затрагивают компоненты Kernel и WebKit соответственно. Эксплуатация осуществляется с помощью zero-click эксплоитов для iMessage. Обнаружены специалистами «Лаборатории Касперского» в ходе изучения вредоносной кампании «Операции Триангуляция» (Operation Triangulation).

Рейтинг CVSS v3.1 - 7.8, 8.8 (соответственно)

Уязвимость устранена.

02 CVE-2023-28252 Microsoft



Уязвимость связана с повышением привилегий до уровня SYSTEM в драйвере Windows Common Log File System (CLFS). Проблема влияет на все поддерживаемые серверные и клиентские версии Windows и может быть использована локальными злоумышленниками в атаках, не требующих взаимодействия с пользователем. По данным «Лаборатории Касперского», эта 0-day уязвимость использовалась операторами вымогателя Nokoyawa.

Рейтинг CVSS v3.1 – 7.8.

Уязвимость устранена.

03 CVE-2023-3029 Google Chrome



Уязвимость, возникающая из-за путаницы типов в движке JavaScript версии 8 в Google Chrome до версии 114.0.5735.110. Уязвимость позволяет удаленному злоумышленнику потенциально использовать повреждение кучи через созданную HTML-страницу. Актуальна для всех браузеров на базе Chromium: Opera, Brave, Microsoft Edge и др.

Рейтинг CVSS v3.1 – 8.8.

Уязвимость устранена.

04 CVE-2023-34416 Mozilla Firefox



Разработчики Mozilla сообщили, что в версиях Firefox 113, Firefox ESR 102.11 и Thunderbird 102.12 имеются ошибки безопасности при работе с памятью, некоторые из которых могут привести к её повреждению. Эта уязвимость затрагивает Firefox ESR < 102.12, Firefox < 114 и Thunderbird < 102.12. Предполагается, что данная уязвимость безопасности памяти, CVE-2023-34416, может быть использована для запуска произвольного кода.

Рейтинг CVSS v3.1 – 9.8.

Уязвимость устраняется.

УТЕЧКИ

Утечки данных являются одной из самых опасных угроз для компаний. Помимо рисков проникновения в инфраструктуру, наличие утечек также наносит ощутимый удар по репутации и финансовому состоянию любой организации.

- 12 мая издание «Ведомости» со ссылкой на данные ИБ-компаний сообщили, что в 2025-м году количество утечек из российских коммерческих компаний и госорганизаций по разным оценкам увеличилось в **1.5-2.5 раза** по сравнению с аналогичным периодом прошлого года.
- По данным Kaspersky Digital Footprint Intelligence за первые 5 месяцев этого года на теневых форумах было обнаружено почти **200 миллионов строк** пользовательских данных, включая **81 миллион** с номерами телефонов и **23 миллиона** с паролями.
- Компания BakerHostetler в своем отчете привела статистику, согласно которой в **1160 расследованных инцидентах** около 40% жертв вымогателей соглашались заплатить выкуп за восстановление и нераспространение похищенных данных.



* По данным исследования InfoWatch

В 3 квартале в публичных утечках выявлено **500 корпоративных учётных записей ООО «Инсека»**. Большинство из них присутствовали в выложенной в открытом доступе базе данных клиентов страховой компании **«Жизнь»**. Также корпоративные учётные данные были обнаружены в утечках В каждом из случаев проведена разъяснительная работа с пользователями, зарегистрировавшимися на внешних ресурсах с указанием корпоративных почт, о недопустимости подобных действий.

SUPPLY CHAIN

Атаки на цепочку поставок (supply chain attacks) — это киберинциденты, в ходе которых злоумышленник внедряет вредоносный код в программное или аппаратное обеспечение, поставляемое третьими лицами.

Статистика последних лет показывает, что атаки на цепочку поставок из набирающего популярность тренда превратились в один из основных векторов атак злоумышленников. В конце 2022 года эксперты обнаружили **88000 вредоносных пакетов** с открытым исходным кодом, что соответствует **742-процентному увеличению** количества подобных программ всего за три года. Также не стоит забывать про резонансные атаки на проприетарное ПО, в результате которых были скомпрометированы инфраструктуры многих компаний.

Текущий квартал не стал исключением. Атаки на цепочку поставок продолжаются.



SUPPLY CHAIN

Компрометация приложения 3CX

Обнаруженная 29 марта 2023 г. кампания, в рамках которой злоумышленники распространяют троянизированные установщики популярного инструмента для голосовых и видео конференций 3CXDesktopApp, продолжилась и во втором квартале. Исследователям удалось выяснить, что вместе со стилером в рамках атаки на цепочку поставок 3CX распространяется и другая вредоносная полезная нагрузка. Организаторы атаки также внедряют на целевых системах полнофункциональный модульный бэкдор Gopuram, который многие исследователи приписывают северокорейской группировке Lazarus.

Множественные атаки через уязвимость в MOVEit

27 мая стало известно о первых атаках на популярное приложение для управления передачей файлов MOVEit Transfer. В ходе атак эксплуатируется уязвимость CVE-2023-34362, с помощью которой злоумышленники размещают на уязвимых серверах кастомные веб-шеллы, что позволяет им получить список файлов, хранящихся на сервере, скачать файлы, а также похитить учетные данные и секреты учетных записей Azure Blob Storage, включая параметры AzureBlobStorageAccount, AzureBlobKey и AzureBlobContainer.

Аналитики Microsoft связали атаки с вымогательской хак-группой Clor. За короткий период времени оказались скомпрометированы сотни компаний. Среди жертв British Airways, Агентство США по кибербезопасности и безопасности инфраструктуры (CISA), подразделения Министерства энергетики США, нефтегазовая компания Shell, Jaguar, Land Rover, BBC, Siemens Energy и др. Полный перечень пострадавших опубликован на Data Leak сайте злоумышленников, где они также выставили требования о выкупе.

DDOS-АТАКИ

По-прежнему продолжают DDoS-атаки на российские информационные ресурсы со стороны политически-мотивированных хактивистов.

Аналитики Qrator Labs обнаружили, что **продолжительность DDoS-атак** на российские IT-ресурсы **сократилась более чем в шесть раз** с прошлого года и стала в среднем равна двум суткам.

Сокращение атак связывают в том числе с успешной блокировкой входящего трафика по геолокации: атаки из-за рубежа становятся неэффективными. По этой причине на серых рынках вырастают в цене российские socks-сервера, что значительно повышает стоимость мощной DDoS-атаки.

Хактивисты из группировки **«ITArmyofUkraine»** сменили вектор атак с финансовых организаций России на страховые.

10 апреля электронные ресурсы **Федеральной Таможенной Службы** подверглись кибератаке. На таможенных пунктах был временно введен режим бумажного документооборота.

25-26 апреля DDoS-атаки привели к временной неработоспособности **порталов для бухгалтеров** klerk.ru, glavbukh.ru, buhsoft.ru и audit-it.ru.

Специалисты StormWall сообщали о продолжающихся все майские праздники DDoS-атаках на **музеи, театры** и **агрегаторы билетов**. В числе жертв оказались и **операторы платных дорог**.

В сравнении с этим периодом прошлого года количество DDoS-атак на сферу культуры выросло на **62%**, на онлайн-сервисы для бронирования билетов и отелей — на **36%**, на транспортные системы — на **28%**.

ПРОГНОЗЫ 2026

Наблюдаемые и анализируемые данные дают нам основания полагать, что в следующем квартале количество угроз ИБ будет оставаться **на прежнем высоком уровне**.

Злоумышленники за последний год накопили большой опыт при совершении компьютерных атак на реальные инфраструктуры жертв. В свободном доступе также оказалось большое количество конфиденциальных данных, которые могут быть легко использованы при совершении атак с применением методов социальной инженерии и шантажа. Мы считаем, что впереди нас ждёт еще много резонансных компьютерных атак, крупных утечек данных, и рекордных по мощности DDoS-атак.

Хактивисты, активно поддерживаемые правительствами прозападных стран, продолжают совершать свои нападки на российские компании.

Отсутствие каких-либо значимых последствий для компаний, допустивших утечки конфиденциальных данных, в том числе со стороны регулирующих органов, позволяет сделать вывод о том, что **количество утечек не будет снижаться**. То же самое можно сказать и об активности атакующих.

В первом квартале тема **0-day** уязвимостей обошла стороной российские компании. Уязвимость в MOVEit Transfer не была актуальна для России, по причине не популярности данного ПО. Во втором квартале может так не повезти.

Геополитические конфликты и напряженность в отношениях стран даёт основание предполагать, что активность **APT-группировок** будет продолжать расти. Будут появляться новые группировки, а также ответвления от уже существующих.

Киберпреступники продолжают пользоваться методами социальной инженерии в **фишинговых и скамерских атаках**. Будет активно использоваться тема российско-украинского политического конфликта и западных санкций

Продолжатся массированные **DDoS-атаки** на российские онлайн-ресурсы.

Под прикрытием DDoS-атак будут совершаться другие зловередные действия, направленные на компрометацию инфраструктуры жертв.

Ранее неизвестные для российских защитников атаки **шифровальщиков** стали одним из главных элементов ландшафта киберугроз отечественных компаний. В следующем квартале ожидаем **увеличения** подобных атак.

Согласно статистике, раз в квартал в мире происходит минимум одна резонансная **Supply chain** кампания. Возьмём на себя смелость сделать прогноз о том, что и в следующем квартале данный тренд останется неизменным и мы будем наблюдать новые кейсы.